

Cyber Tabletop Exercise

Telecommunications Customer Portal DDoS

Prepared for: Continental Telecom Services
Sector: Telecommunications
Generated: June 22, 2026
Exercise classification: Internal / Exercise Use Only

Scenario source: STIX 2.1 bundle — Telecommunications DDoS Tabletop Exercise

1. Executive Summary

This tabletop exercise simulates a large-scale distributed denial-of-service attack against Continental Telecom Services's Customer Self-Service Portal, a customer-facing portal used for billing, account management, and service requests. The exercise is designed to test operational detection and mitigation, executive escalation, customer communications, third-party coordination, business continuity, and post-incident governance.

The scenario begins with customer reports of portal unavailability and call center congestion, progresses through network-level traffic analysis and botnet indicators, and culminates in emergency filtering, upstream provider coordination, customer messaging, and recovery validation.

2. Exercise Design Overview

Exercise type	Discussion-based cybersecurity tabletop exercise
Recommended duration	90 minutes, including debrief
Audience	Executive crisis leaders, business operations, SOC/security, network operations, IT service management, legal, communications, customer support, vendor/provider management
Primary asset	Customer Self-Service Portal — Customer-facing portal used for billing, account management, and service requests.
Threat actor	DDoS Extortion Crew (crime-syndicate)
Incident	Telecommunications Customer Portal DDoS
Exercise tempo	Four timed injects over one simulated business day
Primary ATT&CK reference	Network Denial of Service (T1498)

3. Objectives

- Validate detection, triage, and severity assessment for high-volume application and network-layer DDoS conditions.
- Test coordination between SOC, network operations, IT service management, call center, communications, legal, executive leadership, and upstream providers.
- Evaluate decision-making for emergency traffic filtering, rate limiting, scrubbing service activation, and customer-facing status updates.
- Assess business continuity arrangements for billing, account management, and service request channels during portal degradation.
- Confirm escalation thresholds, crisis governance, internal/external communications, and post-incident reporting expectations.
- Identify lessons learned and improvement actions for DDoS preparedness, resiliency, observability, and stakeholder response.

4. Scope and Assumptions

In Scope

- Customer portal availability and service degradation impacts.
- SOC and network operations response to DDoS indicators.
- Customer support surge management and alternate channels.
- Executive decision-making, legal/regulatory considerations, and public communications.
- Third-party coordination with upstream network providers and DDoS mitigation services.

Out of Scope

- Live technical testing, production changes, or traffic filtering during the exercise.
- Attribution beyond the scenario-provided threat actor profile.
- Detailed forensic malware analysis; no endpoint compromise is assumed unless introduced by facilitator.

Assumptions

- The portal is a critical customer-facing service but not the core switching or mobile network platform.
- No confirmed data breach exists at exercise start; availability is the primary impact.
- DDoS mitigation vendors and upstream providers are contractually available, but response times and authorization paths must be tested.
- Participants should act according to real roles, procedures, thresholds, and constraints.

5. Rules of Engagement

- Real incidents take priority. Participants may step out if operational duties require it.
- This is a no-fault learning exercise; there are no perfect answers.
- Do not fight the scenario. Use realistic assumptions when information is incomplete.
- Make decisions as your real organization would, including escalation, approvals, documentation, and communications.
- Facilitators may accelerate or pause the timeline to explore decision points.

6. Roles and Responsibilities

Role / Function	Primary focus during exercise	Key decisions or outputs
Executive / Crisis Lead	Overall crisis governance and risk acceptance	Activate crisis structure, approve customer/public posture, prioritize business impacts

SOC / Security Incident Response	Security triage and threat assessment	Confirm cyber incident classification, monitor indicators, maintain incident chronology
Network Operations	Traffic analysis and mitigation execution	Engage upstream providers, implement filtering, route to scrubbing, validate service restoration
IT Service Management	Incident ticketing, severity, and coordination	Set severity, manage bridge calls, document decisions and owners
Customer Support / Call Center	Customer impact and contact volume management	Activate surge scripts, route customers to alternate support, track customer pain points
Communications	Internal, customer, and media messaging	Prepare status page updates, advisories, FAQs, and holding statements
Legal / Privacy / Compliance	Regulatory and contractual implications	Assess notification obligations, approve external messaging, preserve evidence

7. Scenario Narrative

Continental Telecom Services experiences sudden unavailability of its Customer Self-Service Portal. Customers cannot access billing, account management, or service request functions. Call center traffic rises sharply as users seek assistance through alternate channels. Network operations soon observes a traffic spike exceeding normal baseline by more than 500 percent. The traffic originates from widely distributed global sources and shows botnet-like characteristics, including repeated HTTP requests, spoofed headers, and high source diversity across residential networks. The working hypothesis becomes a DDoS extortion campaign targeting customer-facing telecommunications services.

The organization must balance fast mitigation with customer transparency, operational continuity, legal/compliance oversight, and coordination with external network providers. The scenario is resolved once emergency filtering and mitigation are enabled, customer messaging is released, and service restoration is validated.

8. Exercise Timeline and Injects

Inject 1 – Portal Unavailable (09:00)

Customers report that the self-service portal is unavailable. Call center volume increases sharply as users cannot access billing and account services.

Discussion questions	- How is the incident detected and validated? - Who owns the first severity assessment and incident bridge? - What immediate customer and operational impacts must be understood? - What information is needed before calling this a cyber incident?
Expected actions	- Open incident ticket and assign incident commander or service owner. - Confirm scope: portal only, geography, customer segments, error rates, call volume, and business services affected. - Start internal situation report and timeline. - Prepare initial holding language for customer support without over-attribution.
Facilitator notes	Keep participants focused on availability and customer impact. Do not introduce botnet details until Inject 2 or 3 unless they ask what evidence exists.

Inject 2 – Traffic Spike (10:00)

Network operations observes a traffic spike exceeding normal baseline by more than 500 percent, with high-volume requests from distributed global sources.

Discussion questions	- What technical telemetry confirms a DDoS versus normal customer demand or application failure? - When should the SOC, network operations, crisis cell, communications, legal, and third parties be engaged? - What authorization is needed to activate rate limiting, scrubbing, geofencing, or upstream filtering? - What business functions are most affected if the portal remains unavailable for several hours?
Expected actions	- Escalate to security incident response and network DDoS playbook. - Engage DDoS mitigation provider and upstream carriers under predefined contacts. - Assess customer support surge capacity and alternate service channels. - Define severity based on customer impact, duration, and criticality.
Facilitator notes	Probe whether participants know DDoS vendor contacts, approval paths, traffic-routing dependencies, and rollback criteria.

Inject 3 – Botnet Indicators (11:30)

Security teams identify botnet-like traffic patterns, including repeated HTTP requests, spoofed headers, and source diversity across residential networks.

Discussion questions	- What indicators should be shared internally and externally? - How do teams avoid blocking legitimate customers while reducing malicious traffic? - What is the threshold for executive notification or crisis cell activation? - How should the organization respond if an extortion demand is received during the attack?
Expected actions	- Tune WAF/CDN/rate-limiting rules and monitor false positives. - Coordinate with upstream providers for filtering and scrubbing. - Preserve logs and packet metadata relevant to the incident.

	• Prepare executive brief with impact, mitigation status, risks, and customer messaging options.
Facilitator notes	Optionally introduce a facilitator-only prompt: an extortion email claims responsibility but provides no credible proof. Expected response is preserve evidence, notify legal/security leadership, and do not negotiate ad hoc.

Inject 4 – Filtering and Communications (13:00)

Emergency traffic filtering is enabled with upstream providers. Communications teams prepare customer messaging about degraded online services.

Discussion questions	• What must be verified before announcing service restoration or improvement? • What should customer messaging say, and what should it avoid saying? • Who approves external communications and regulatory or contractual notifications? • What post-incident activities are required after service stabilizes?
Expected actions	• Validate portal availability, error rates, and customer transaction success from multiple regions. • Publish customer advisory and support-channel guidance; update status page cadence. • Document mitigation actions, approvals, and residual risks. • Begin post-incident review, lessons learned, and resilience improvement plan.
Facilitator notes	Drive the group toward recovery governance, not just technical mitigation. Ask what evidence supports closing or downgrading the incident.

9. Key Decision Points

Decision point	Prompt	Evidence / criteria
Severity and escalation	When does portal degradation become a cyber incident or crisis event?	Severity matrix, customer impact, duration, criticality, service-level thresholds
Mitigation activation	Who can authorize emergency filtering, scrubbing, or rate limiting?	Preapproved runbooks, risk acceptance, customer false-positive tolerance
Customer transparency	What is communicated before root cause is fully confirmed?	Status page cadence, support scripts, plain-language impact, avoid unsupported attribution
Business continuity	Which services require alternate processing or manual support?	Billing inquiries, account changes, service requests, vulnerable customers, priority enterprise customers
External coordination	Which providers, regulators, or law enforcement contacts are engaged?	Contractual SLAs, provider escalation contacts, legal/compliance thresholds
Recovery and closure	What evidence supports downgrade or closure?	Traffic normalization, portal health checks, support volume, residual attack monitoring, post-incident report

10. Technical and Business Impact Areas

Technical impacts

- Sustained HTTP request floods and possible network-layer saturation.
- Portal latency, timeouts, authentication failures, and transaction abandonment.
- Potential collateral impact from aggressive filtering or geofencing.
- Increased monitoring load for SOC and network operations teams.

Business impacts

- Customers unable to access billing, account management, or service requests.
- Sharp increase in call center demand and customer frustration.
- Brand and trust impact if messaging is delayed or inconsistent.
- Potential contractual or regulatory scrutiny for prolonged service outage.
- Operational pressure on support teams and enterprise customer account managers.

11. Facilitator Guide

- Start by reminding participants that the goal is to test decisions, coordination, and communications rather than technical perfection.
- Ask participants to identify the real owner for each decision and artifact: ticket, bridge, customer message, provider escalation, legal assessment, and executive update.
- Challenge assumptions about who can approve emergency changes and how those decisions are documented.
- Periodically ask what is known, what is assumed, what remains unknown, and what must be communicated despite uncertainty.
- Capture gaps as improvement actions with owner, due date, and target control or process.

12. Debrief and Lessons Learned

Use the final 15–20 minutes to capture observations, strengths, and improvement actions.

- What worked well in detection, escalation, and coordination?
- Where were roles or approval paths unclear?
- Were DDoS provider contacts, contracts, and runbooks immediately available?

- Did customer and executive communications keep pace with the incident?
- What technical telemetry was missing or difficult to interpret?
- What changes are required to reduce customer impact in a future event?

Improvement area	Recommended action	Owner	Target date
DDoS runbook			
Provider escalation			
Customer communications			
Monitoring and alerting			
Business continuity			

13. MITRE ATT&CK Mapping

The scenario maps primarily to the Impact tactic, with supporting defensive observations for detection and response.

Tactic	Technique	ID	Scenario evidence	Expected defenses / response
Impact	Network Denial of Service	T1498	High-volume distributed traffic disrupts customer-facing telecommunications services.	DDoS playbook, upstream filtering, scrubbing, rate limits, traffic baselining, resilience testing
Impact	Endpoint / application resource exhaustion (represented as service availability loss)	T1498-related	Repeated HTTP requests and spoofed headers contribute to portal unavailability.	WAF/CDN rules, request throttling, bot management, synthetic monitoring, false-positive review

Appendix A - Source STIX Elements Used

Identity	Continental Telecom Services
Infrastructure	Customer Self-Service Portal — Customer-facing portal used for billing, account management, and service requests.
Threat actor	DDoS Extortion Crew
Incident	Telecommunications Customer Portal DDoS
Course of action	Activate DDoS Mitigation; Customer Communications Response
Inject notes	Inject 1 - Portal Unavailable; Inject 2 - Traffic Spike; Inject 3 - Botnet Indicators; Inject 4 - Filtering and Communications

Appendix B - Glossary

Term	Definition
DDoS	Distributed Denial of Service; an attempt to make a service unavailable by overwhelming it with traffic.
SOC	Security Operations Center.
WAF	Web Application Firewall.
CDN	Content Delivery Network.
Scrubbing service	A mitigation service that filters malicious traffic before forwarding clean traffic to the protected environment.
False positive	Legitimate traffic incorrectly blocked or challenged by security controls.